



Faisal D'Souza
National Coordination Office
Networking and Information Technology Research and Development
National Science Foundation
2415 Eisenhower Avenue
Alexandria, VA 22314

RE: Palo Alto Networks' Comments in Response to NSF Request for Information on the Development of an Artificial Intelligence (AI) Action Plan

This document is approved for public dissemination. The document contains no business-proprietary or confidential information. Document contents may be reused by the government in developing the AI Action Plan and associated documents without attribution.

Introduction:

Palo Alto Networks applauds the Trump Administration's innovation-first approach to AI. We welcome the opportunity to provide comments in response to the Request for Information (RFI) from the Office of Science and Technology Policy (OSTP) and the Networking and Information Technology Research and Development (NITRD) National Coordination Office on the Development of an Artificial Intelligence (AI) Action Plan.

As the global cybersecurity leader, Palo Alto Networks has unique insight into AI's impact on cybersecurity. We see firsthand how AI amplifies the scale and speed of attacks for threat actors, as well as revolutionizes threat detection and defense strategies, ultimately giving cyber defenders the upper hand against malicious actors.

Palo Alto Networks firmly believes it would be more risky for society to *not* meaningfully leverage AI for cyber defense purposes. We are aggressively innovating and investing to ensure we can continue delivering superior security outcomes while streamlining inefficient, and time-consuming manual practices.

Our product suite – which spans network security, cloud security, endpoint security, and security operations center (SOC) automation – has successfully leveraged AI and machine learning (ML) for many years to help organizations stay a step ahead of attackers.

Each day, Palo Alto Networks detects up to 8.9 million unique attacks that are novel or previously unseen. This real-time awareness of the threat landscape through continuous discovery and analysis allows our company to block up to 30.9 billion attacks each day. None of this would be possible without AI.

Palo Alto Networks has invested in AI for cybersecurity for over a decade and, more recently, in the security of AI. As such, we are able to share deep technical expertise and offer a unique perspective to OSTP & NITRD that can help inform the development of an AI Action Plan.

Overarching Recommendations for the AI Action Plan:

As outlined in greater detail below, we recommend that the Trump Administration prioritize the following in the development of an AI Action Plan:

- Embrace AI's ability to turbocharge cyber defense;
- Promote AI-driven SOC's to 1) deliver transformative cybersecurity outcomes, 2) drive substantial cost rationalization, and 3) eradicate cybersecurity workforce inefficiencies;
- Develop voluntary AI security standards to help harden the expanding AI attack surface (we call this *Secure AI by Design*); and
- Support a uniform, government-wide, and risk-based approach to AI procurement that enhances security and efficiency across federal agencies.

The Backdrop – Increasing Adversarial Sophistication:

Cyber adversaries are already leveraging AI to advance their tradecraft and will continue to do so going forward. For example, we see evidence that adversaries are using AI to enhance what we call social engineering attacks – phishing emails designed to lure users to “click the link.”

Historically, these messages have been littered with poor grammar and typos, making their fraudulent nature relatively easy to detect, but they are becoming more accurate and therefore more believable. Adversaries are now able to generate flawless, mistake-free text, enabling click-through rates to skyrocket.

Additionally, bad actors are innovating with AI to accelerate and scale attacks and find new attack vectors. They can now execute numerous simultaneous attacks on one company across multiple vulnerabilities. Adversarial use of AI allows faster lateral movement within networks and more rapid weaponization of reconnaissance data.

Our most recent data highlights that AI can take the time to data exfiltration from the median of two days down to 25 minutes – about 100 times faster.

Going forward, there is the potential for a significant surge in malware variants as the cost of creating customized malware drops substantially. None of this should be a surprise. Adversaries are always evolving, with or without AI, and we can never be complacent. As cyber defenders, our mission is to understand and track adversarial capability while relentlessly innovating and deploying best-in-class security tools to stay ahead of the threat.

AI-Powered Cyber Defense Drives Innovation and Efficiency:

For too long, our community's most precious cyber resources – people – have been inundated with security alerts that require manual triage, forcing them to play an inefficient game of “whack-a-mole,” while vulnerabilities remain exposed and critical alerts are missed.

This inefficient, manual posture results in suboptimal Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR) intervals for security operations teams. As the terms suggest, these metrics provide quantifiable data points for network defenders about how quickly they discover

potential security incidents and then how quickly they can contain them. Historically, organizations have struggled to execute against these metrics.

Much of this historical struggle can be attributed to complexity – with the average enterprise’s security stack including 83 discrete solutions across 29 different vendors. Integrating this data and making it actionable is nearly impossible with legacy, outdated SOC practices. Indeed, our annual incident response report highlights that in 75% of major breaches, logging data existed that should have alerted defenders to anomalous behavior – but those data points were buried and never appropriately actioned. As a result, enterprises take close to six days to respond to cybersecurity incidents while sensitive data can be exfiltrated in just hours. This imbalance threatens our national security and gives adversaries the advantage.

Fortunately, AI-driven SOC’s are actively flipping this paradigm to give defenders the upper hand. This technology acts as a force multiplier for cybersecurity professionals to substantially reduce detection and response times.

Massive amounts of security data – across the network, endpoint, and cloud – are now enriched, stitched, and correlated in real-time to more effectively separate the signal from the noise. This enhances threat detection, significantly reducing the time between a potential incident and discovery. These AI-powered SOC’s automatically categorize and prioritize alerts, drastically reducing the flood of false positives that historically overwhelmed SOC analysts.

Early results from deploying this technology for our own company networks have been significant:

- On average, we ingest 59 billion events daily.
- Using AI-driven data analysis, we automatically triage that number down to just one security incident that requires manual action by the SOC.
- We have reduced our MTTR to just one minute for high priority alerts.

The benefits of AI-powered SOC’s across our customer base are also substantial. Enterprises on average ingest 4x the security data each day, see a reduction in response times from 2-3 days down to under two hours; and a 5x increase in incident close out rate.

In light of these transformative cybersecurity outcomes, we encourage the government to embrace AI-powered security operations to protect national security while driving efficiency.

The Expanding AI Attack Surface Necessitates an Evolved AI Security Toolkit:

Organizations across all industries are racing to use AI to achieve a competitive advantage with the number of enterprises using AI more than doubling over the last year. As AI becomes more widely adopted, it will exponentially expand the attack surface and present new security considerations that must be navigated.

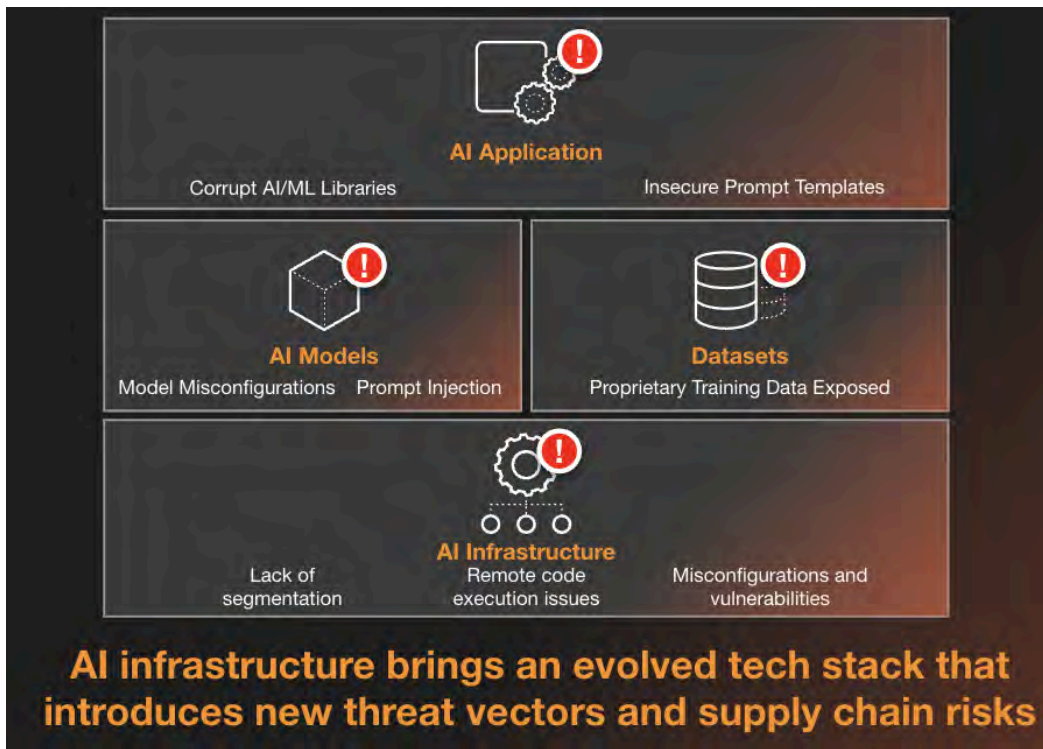
For example, when organizations adapt and customize LLMs for specific applications, the

process often involves exposing the model to sensitive internal information during training. Strong data governance practices are required to ensure that only authorized data is used for fine-tuning and that the resulting models are secured against risks like data poisoning attacks, when an adversary intentionally injects malicious examples into the training data to manipulate model behavior.

The adoption of GenAI apps also presents a double-edged sword. As workers gravitate toward GenAI apps to drive greater productivity, shadow IT morphs into shadow AI. This lack of visibility into an organization's "shadow AI" usage can lead to serious security implications, including data leakage onto sanctioned third-party applications, the absence of granular, role-based access controls, employee and customer risks from malicious links in chatbox responses, and potential vulnerabilities from blind spots in plugin management.

Furthermore, research indicates that 55% of employees currently use AI apps *without* permission in their enterprise, and 80% of public models can be "jailbroken" (bypassing restrictions installed by model creators).

These realities present an opportunity for the Trump Administration to champion voluntary Secure AI by Design frameworks and best practices that would promote a new approach to AI security that is rooted in innovation and growth. This stands in contrast to approaches that lead to regulatory overreach and complex compliance patchworks that companies have previously struggled to navigate. By embedding security considerations into the AI development and deployment process from the outset, organizations can proactively mitigate risks and build more resilient AI systems.



Securing AI by Design:

To safely adopt AI tools and deploy enterprise AI applications and models, organizations need the ability to:

1. Discover and manage employee usage of third-party AI applications;
2. Secure every step of the AI app development lifecycle and supply chain; and
3. Protect AI models, data, and AI applications in real-time.

Key features of these three Secure AI by Design pillars are enumerated below.

1. Discover and manage employee usage of third-party AI applications:

- *User Access Controls.* Classify apps as sanctioned, unsanctioned, or tolerated, and implement access controls based on classification and use case.
- *Data Loss Prevention (DLP).* The ability to detect sensitive data inline and block sensitive text- and file-based data transfer to GenAI apps.
- *Security Posture Management.* Visibility into GenAI plugins detected via GPT marketplaces with the ability to detect, monitor, and remediate unauthorized AI bots. Control access, monitor permissions, and implement protection for app configurations.
- *Threat Protection.* Block malicious URLs and files in GenAI responses with zero

trust network architecture. Generate high-fidelity alerts and reporting for security inspections and a unified data map for holistic security awareness.

- *End-User Notifications.* Alert end users when unapproved apps are accessed or if sensitive data is detected. End user notifications should be natively integrated with email, video messaging platforms, and other team collaboration applications.

2. Secure every step of the AI app development lifecycle and supply chain:

- *Visibility and Discovery.* Lacking an AI inventory can lead to shadow AI models, compliance violations, and data exfiltration through AI-powered applications. Organizations need the ability to discover and maintain an inventory of all AI models being used across their cloud environments.
- *AI Detection and Response.* Gain visibility into AI infrastructure and interactions by users, detect AI-related attacks, and perform remediation and response actions accordingly.
- *Data Governance.* Organizations need strong controls around AI usage and customer data fed into AI applications. This includes the traceability of model lineage, approvals, and risk acceptance criteria, and achieving policy compliance by mapping human and machine identities with access to sensitive data or AI models.
- *Vulnerability Management.* Enable organizations to identify vulnerabilities and misconfigurations in the AI supply chain that could lead to data exfiltration or unauthorized access to AI models and resources. This entails mapping out the full AI supply chain of source data, reference data, libraries, APIs, and pipelines powering each model. This information could then be analyzed to identify improper encryption, logging, authentication, or authorization settings.
- *End-to-End Monitoring and Analysis.* User interactions, prompts, and inputs to AI models (like LLMs) must be continuously monitored to detect poisoning, misuse, prompt overloading, unauthorized access attempts, or other abnormal activity. Scanning the outputs and logs of AI models to identify potential instances of sensitive data exposure is an effective way to assess model behavior and detect anomalies or incidents.
- *Risk Mitigation and Response.* Enable rapid response workflows when high-priority security incidents or policy violations are detected around data or the AI infrastructure. This provides visibility into the context and stakeholders for remediation of identified risks or misconfigurations.

3. Protect AI models, data, and AI applications in real-time:

- *Application or Model Protection.* Leverage state-of-the-art cloud-delivered security services to help block prompt injection and denial of service attacks, all while preventing model misuse and safeguarding model integrity.
- *Advanced URL Filtering.* Enable organizations to detect and scan URLs going between their AI applications and models.
- *Data Loss Protection.* DLP helps prevent data exfiltration, shielding datasets from corruption and poisoning.
- *Runtime Monitoring.* Safeguard AI environments with constant analysis of AI runtime risk posture that offers clear insights into vulnerabilities within operational AI systems.
- *Segmentation Security.* Enable detailed segmentation of all application components within an environment to secure every communication pathway, from port-to-port to namespace-to-namespace traffic, preventing both known and unknown attacks.

Recommendations to Maximize AI's Potential for Cybersecurity:

Palo Alto Networks applauds the Trump Administration's innovation-first approach to AI. A voluntary risk-based and stakeholder-involved approach to AI development and use will help minimize harms without stifling necessary innovation. We offer the following considerations as we look to further encourage the deployment of AI-driven solutions for cyber defense:

Promote AI for Cybersecurity and Cybersecurity for AI

- Embrace AI's ability to turbocharge cyber defense. To that end, promote AI-driven SOC's to 1) deliver transformative cybersecurity outcomes, 2) drive substantial cost rationalization, and 3) eradicate cybersecurity workforce inefficiencies.
- Develop voluntary AI security standards to help harden the expanding AI attack surface (we call this *Secure AI by Design*). Central to this posture is enabling visibility and control over AI infrastructure:

Visibility is about gaining a clear understanding of how AI is being used across the organization. It includes maintaining an inventory of all deployed AI applications and models, tracking what data is being used to train and operate these models, and documenting the capabilities and access permissions of each model. Without this foundational visibility, it is impossible to assess risk or enforce policies.

Control refers to the policies, processes, and technical safeguards needed to ensure that AI is being used as intended. It includes data governance policies that determine what information can be used for AI, access controls set by enterprises that restrict who can

develop and deploy models, and ongoing monitoring and auditing capabilities to validate model behavior and performance.

Promote Workable Federal AI Procurement Policies

Palo Alto Networks encourages the Trump Administration to pursue an innovation-forward procurement environment that promotes competition within the federal marketplace. It is important to modernize government acquisition processes to keep pace with technological advancements, enabling more effective procurement of commercial AI solutions:

- Any new guidelines regarding government adoption or procurement of AI should employ a logical and consistent risk identification framework to ensure policymakers effectively address the actual risks they seek to mitigate. This requires a uniform, government-wide approach to AI procurement and risk management.
- We recommend the Trump Administration pivot away from guidance issued under Office of Management and Budget (OMB) Memorandums M-24-10 and M-24-18, which embraced unclear categorizations of “rights-impacting” and “safety-impacting” AI to determine government adoption of this dynamic technology. Instead, the government should support use case-specific guidance for developers and deployers of clearly defined “high risk” AI systems to prevent scoping in and restricting the adoption of lower-risk, routine enterprise use cases.
- Palo Alto Networks strongly urges the Trump Administration to revise this OMB guidance and appropriately scope it to promote the vital role that AI plays in the prevention, detection, and investigation of cybersecurity incidents and ensure these important functions are appropriately recognized in procurement guidelines and the AI Action Plan.

Promote Sensible, Risk-Based Policymaking

As policymakers at the federal and state levels continue crafting risk-based proposals intended to harness AI innovation while mitigating potential harms, we urge them to consider the following:

- *Build Upon Flexible Frameworks.* The NIST AI Risk Management Framework (RMF) serves as a thoughtfully crafted baseline for understanding AI risk that can serve as the cornerstone for any organization or policymaker. The RMF allows organizations to assess their needs and capabilities against the idiosyncratic circumstances in which they use, develop, or deploy AI systems – evaluating both the risks and benefits of those systems.

The NIST Cybersecurity Framework (CSF), initially developed to improve the cybersecurity of critical infrastructure, has become one of the most widely adopted security frameworks globally. The CSF is built around five core functions, each intended to play a crucial role in establishing a robust cybersecurity posture, and is flexible

enough to be integrated with the existing security processes within any organization. It is important to recognize the need for robust security measures to address the unique challenges AI systems present. To that end, we welcome recent efforts announced by NIST to crosswalk principles from the CSF into an AI-specific security profile.

- *Differentiate Between Use Cases, Impacts, and Data Types.* Policymakers should employ a risk-based approach that takes into account differences in the use cases, the data processed in those use cases, and the potential resulting impacts on individuals. We urge OSTP and NITRD to carefully consider the varied nature of AI use cases to ensure that any new guardrails are flexible and do not unintentionally inhibit the continued and expanded use of AI-powered tools for cyber defense.
- *Develop Thoughtful Definitions and Thresholds to Prevent Fractured Approaches to AI.* State legislatures are quickly moving out with competing and often burdensome AI requirements that will lead to a confusing compliance patchwork, similar to what companies face with respect to privacy requirements. Some of these proposals introduce inconsistent definitions and risk thresholds, confuse the roles and responsibilities of actors across the AI value chain, impose requirements that are unworkable in practice, and even contradict cybersecurity and data protection standards.
- *Recognize the Benefits of Federal Preemption.* Regulation in any one state is likely to have implications for AI development nationwide, resulting in a fragmented AI landscape that will ultimately hamstring innovation and the nation's ability to fully leverage its strategic advantage. The United States would greatly benefit from a single, holistic, and workable national framework rather than a patchwork of state requirements.
- *Ensure Disclosure Requirements Do Not Inadvertently Harm National Security.* We recognize that impact assessments and risk management disclosures for AI models are increasingly being proposed to improve AI transparency. We urge any proposal to take into account the potential national security impact when considering the scope and nature of disclosure requirements. For example, public disclosures that require information detailing how network defenders use and train AI systems to secure networks could unintentionally create a roadmap for cyber adversaries to break through those defenses, in turn jeopardizing the underlying network security.
- *Recognize Cybersecurity as a Legitimate Interest to Keep America Safe.* No standards or guidelines should restrict a developer or deployer's ability to ensure, maintain, or improve network and information security, or to prevent, detect, protect against, or respond to a cybersecurity incident. Defenders must be empowered to flexibly adopt AI-driven cybersecurity technologies to protect networks and systems in a dynamic and increasingly sophisticated threat landscape.

- *Prevent Inartful Incident Reporting Regimes.* To the extent that there are any new requirements for AI incident reporting, they should focus on clearly defined, significant harms, specifically unintended outcomes or malfunctions unique to AI, and should not cover or impose different thresholds than existing frameworks, such as for the reporting of cybersecurity incidents, which also need to be harmonized. Roles and responsibilities must be clearly defined, especially which entity is responsible for reporting and when.

The protection of training data and algorithms is paramount, and we urge strong protections for those critical pieces of intellectual property and systems information in any incident reporting regime. A repository of incident reports from covered entities across the U.S. and beyond may itself be a valuable target for cyber adversaries. The unauthorized access to or publication of these reports could cause additional security, reputational, regulatory, and potentially financial damage to reporting organizations, which expect and need this information to remain confidential.

Such a scenario could also harm the reputation of government agencies and the private sector's willingness to engage in other, voluntary information sharing and collaboration with government partners. Any AI incident reporting requirements must be harmonized.

Conclusion:

The Trump Administration can drive U.S. AI innovation by promoting AI to improve cybersecurity *and* enhancing the security of AI systems themselves. Palo Alto Networks supports the development of an AI Action Plan that recognizes those imperatives and fosters further technological investment that will optimize efficiency and bolster U.S. economic and national security.